⚠ EDUCATIONAL USE ONLY

REPORT ID: FUTURE-CS-01-2026

Vulnerability Assessment Report

Security Audit — Bose Corporation (bose.com)
Read-Only Passive Scan · HackerOne VDP Authorised

TARGET ORGANISATION	AUDIT DATE	PREPARED BY
Bose Corporation	February 25, 2026	Mohammad Moinuddin
REPORT TYPE	**HACKERONE PROGRAMME**	**OVERALL RISK RATING**
Vulnerability Assessment	hackerone.com/bose_vdp	HIGH

1 Critical | 3 High | 4 Medium | 2 Low

⚠ **FOR EDUCATIONAL AND INTERNSHIP PURPOSES ONLY** ⚠ All testing was conducted passively under Bose's authorised HackerOne VDP. No systems were harmed or attacked.

01 Executive Summary

OVERVIEW & KEY FINDINGS

1	3	4	2
CRITICAL	HIGH	MEDIUM	LOW

This report summarises the results of a security check carried out on Bose Corporation's public websites (**www.bose.com** and related addresses) on February 25, 2026. The goal was to identify any security weaknesses that could be seen without logging in or performing any kind of attack.

This check was carried out under Bose's official security research programme on HackerOne — a trusted platform where companies invite researchers to responsibly report issues. Bose updated this programme on February 10, 2026, and it provides full legal protection for researchers. At no point were any attacks performed, any data accessed, or any systems harmed. Everything was done by simply observing what Bose's websites openly return to any visitor.

Overall Risk Rating: HIGH. The most serious issue found is that one of Bose's websites is accidentally leaking detailed information about its internal computer systems to anyone on the internet. This includes private server addresses, server names, cloud region details, and software version numbers — information that could help an attacker plan a targeted attack. This needs to be fixed urgently.

RISK BREAKDOWN

10 Total Findings

🔴 CRITICAL — 1
🟠 HIGH — 3
🟡 MEDIUM — 4
🟢 LOW — 2

MOST URGENT FINDING

BOSE-001: Internal Kubernetes & Cloud Infrastructure Metadata Exposed on worldwide.bose.com

REPORT NUMBER	FUTURE-CS-01-2026

TARGET ORGANISATION	Bose Corporation
TARGET WEBSITE	www.bose.com / *.bose.com
AUDIT DATE	February 25, 2026
AUDITOR	Mohammad Moinuddin
REPORT TYPE	Vulnerability Assessment (Read-Only Passive Scan)
HACKERONE PROGRAMME	hackerone.com/bose_vdp
AUTHORISATION	Bose VDP — HackerOne Gold Standard Safe Harbor
OVERALL RISK RATING	**HIGH (Multiple Critical Findings)**

02 Scope & Methodology

ASSETS TESTED & APPROACH

2.1 — Scope

The following assets were assessed within the Bose VDP scope on HackerOne:

ASSET	TYPE	COVERAGE
www.bose.com	Primary Domain	✅ **Tested**
worldwide.bose.com	Wildcard Subdomain	✅ **Tested**
support.bose.com	Subdomain	✅ **Tested**
www.bose.ae	Regional Domain	✅ **Tested**
*.bose.com (wildcard)	All Subdomains	In Scope

2.2 — Tools Used

TOOL	PURPOSE
`curl`	HTTP header analysis and response inspection
`nmap`	Port scanning and SSL/TLS cipher enumeration
`whatweb`	Web technology fingerprinting
`dig`	DNS record analysis (SPF, DMARC, DKIM)
`base64`	Decoding of leaked metadata headers
`Kali Linux 2025`	Testing environment (VMware)

2.3 — Methodology

> This security check used only passive, read-only methods — meaning we only looked at information that Bose's websites openly send back to any visitor. We used standard free tools to inspect hidden response data, check email security records, and look for visible software information. No login attempts, no attacks, and no harmful actions were performed at any point. This approach follows the internationally recognised **OWASP Web Security Testing Guide**.

03 Detailed Findings

10 VULNERABILITIES ACROSS 4 SEVERITY LEVELS

3.1 — CRITICAL FINDINGS

BOSE-001

Internal Kubernetes & Cloud Infrastructure Metadata Exposed

CRITICAL

ASSET	worldwide.bose.com
DESCRIPTION	When you visit worldwide.bose.com, the website accidentally sends back hidden technical messages in its response that reveal detailed information about Bose's internal computer systems. These messages — called response headers — are normally invisible to regular users, but anyone with basic tools can read them. By decoding one of these hidden messages, we were able to see the names of Bose's internal servers, their private network addresses, which cloud region they run in (Europe/Ireland), and which software versions they are using — all without logging in or doing anything harmful.

EVIDENCE	`x-envoy-peer-metadata-id: sidecar~10.106.72.149~pulsar-66d98648dc-jj82l.pulsar-v1~pulsar-v1.svc.cluster.local`
	
	`Decoded metadata reveals:`
	`CLUSTER_ID=Kubernetes`
	`INSTANCE_IPS=10.106.72.149`
	`ISTIO_VERSION=1.19.0`
	`AWS_REGION=eu-west-1`
	`AWS_INSTANCE_ID=i-08362642f66f0bddf`
	`NAMESPACE=pulsar-v1`

BUSINESS IMPACT	Think of this like a building that accidentally displays its internal floor plans, security camera locations, and door codes on the outside wall. Anyone passing by can see exactly how the building works and where the weak points are. An attacker who sees this information knows exactly which servers to target, which software versions to look up for known weaknesses, and how Bose's internal network is structured — making any future attack much easier and faster to carry out.
REMEDIATION	Bose's web servers need to be configured to stop including these internal details in their public responses. This is a simple configuration change — a few lines instructing the server to remove these hidden messages before sending responses to the public internet. No major development work is needed; this is a server settings fix that should take a skilled engineer less than a day to implement.

SCREENSHOT EVIDENCE

📷 📷 BASE64 DECODE — CLUSTER_ID, INSTANCE_IPS, ISTIO_VERSION REVEALED

```
┌──(kali㉿kali)-[~]
└─$ echo "ChoKDkFQUF9DT05UQUlORVJTEggaBnB1bHNhcgoaCgpDTFVTVEVSX0lEEgwaCkt1YmV
ybmV0ZXMKHwoMSU5TVEFOQ0VfSVBTEg8aDTEwLjEwNi43Mi4xNDkKGQoNSVNUSU9fVkVSU0lPThII
GgYxLjE5LjA=" | base64 -d 2>/dev/null | strings
APP_CONTAINERS
pulsar
CLUSTER_ID
Kubernetes
INSTANCE_IPS
10.106.72.149
ISTIO_VERSION
1.19.0

┌──(kali㉿kali)-[~]
└─$ curl -sI https://worldwide.bose.com | grep -iE "server|x-powered|via|x-am
z|x-envoy"
server: ambassador-external
x-envoy-decorator-operation: pulsar.pulsar-v1.svc.cluster.local:80/*
x-envoy-peer-metadata: ChoKDkFQUF9DT05UQUlORVJTEggaBnB1bHNhcgoaCgpDTFVTVEVSX0
lEEgwaCkt1YmVybmV0ZXMKHwoMSU5TVEFOQ0VfSVBTEg8aDTEwLjEwNi[illegible]NDkKGQoNSVNUSU9
fV[illegible]CiYKHGFw
cC[illegible]CmRlc
GFy[illegible]8ktMi
4xNi4wC[illegible]0eS5
pc3Rpby[illegible]LW5h
bWUSC[illegible]uM
Tg[illegible]Dx
oN[illegible]UV
TU[illegible]MS9u
YW1[illegible]VEFEQ
VRBE[illegible]ZXOtd2VzdC0xYgooCg9hd3NfaW5zdG
FuY2VfaWQSFRoTaS0wODM2MjY0MmY2NmYwYmRkZgoZCgphd3NfcmVnaW9uEgsaCWV1LXdlc3QtMQo
ZCg1XT1JLTE9BRF9OQU1FEggaBnB1bHNhcg==
x-envoy-peer-metadata-id: sidecar~10.106.72.149~pulsar-66d98648dc-jj82l.pulsa
r-v1~pulsar-v1.svc.cluster.local
x-envoy-upstream-service-time: 38
via: 1.1 54f388662c0be6cc8275058896dbbae6.cloudfront.net (CloudFront)
x-amz-cf-pop: DXB53-P1
x-amz-cf-id: 1bYltTCXlU9Ujg1a6DBbqjT6w5Y4TUNaVEumta9GiKE2h1PZb5KBIw==
```

📷 📷 WORLDWIDE.BOSE.COM — X-ENVOY-PEER-METADATA HEADER EXPOSED

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com/home | grep -iE "x-frame|permissions-policy
|referrer-policy|x-xss"

┌──(kali㉿kali)-[~]
└─$ curl -sI https://worldwide.bose.com/support
HTTP/2 301
content-length: 0
location: https://www.bose.ae/en_ae/support.html
access-control-allow-methods: GET, POST, PUT, DELETE, OPTIONS
access-control-allow-origin: *
cache-control: no-cache, no-store, max-age=0, must-revalidate
date: Wed, 25 Feb 2026 07:26:30 GMT
expires: 0
nebula-response-details: reason: Exact match; rule-id: cdf82dbf-2746-403d-a68
2-1bcdfafd6df1
pragma: no-cache
server: ambassador-external
strict-transport-security: max-age=31536000 ; includeSubDomains
x-content-type-options: nosniff
x-envoy-decorator-operation: pulsar.pulsar-v1.svc.cluster.local:80/*
x-envoy-peer-metadata: ChoK[redacted]
lEEgwaCkt1YmVybmV0ZXMKHwo[redacted]VNUSU9
fVkVSU0lPThIIGgYxLjE5LjAK[redacted]KHGFw
cC5rdWJl[redacted]CmRlc
GF[redacted]D3ktMi
4[redacted]cml0eS5
p[redacted]5pY2FsLW5h
b[redacted]EggaBjEuM
T[redacted]hfSUQSDx
oN[redacted]ngKCU5BTUV
TUE[redacted]WaXMvYXBwcy92MS9u
YW1l[redacted]
VRBEm4q[redacted]
FuY2VfaWQSFRoTaS0wODM2MjY0MmY2NmYwYmRkZgoZCgphd3NfcmVnaW9uEgsaCWV1LXdlc3QtMQo
ZCg1XT1JLTE9BRF9OQU1FEggaBnB1bHNhcg==
x-envoy-peer-metadata-id: sidecar~10.106.72.149~pulsar-66d98648dc-jj82l.pulsa
r-v1~pulsar-v1.svc.cluster.local
x-envoy-upstream-service-time: 8
x-frame-options: DENY
x-xss-protection: 1; mode=block
x-cache: Miss from cloudfront
via: 1.1 a4722330b218f0fafaa9aed657871702.cloudfront.net (CloudFront)
x-amz-cf-pop: DXB53-P1
alt-svc: h3=":443"; ma=86400
x-amz-cf-id: Hm-a-f7ZL9BQWBQRIjsZar-3hP2lMwUfLe8XQEYs1LYlUKTw1ybAlQ==
```

BOSE-002

Missing HTTP Strict Transport Security (HSTS) on Primary Domain

HIGH

ASSET	www.bose.com
DESCRIPTION	When you visit www.bose.com, the website does not send any instruction telling your browser to always use a secure (HTTPS) connection. This instruction is called HSTS (HTTP Strict Transport Security). Without it, if someone tricks your browser into loading the page over an insecure connection, your browser will not automatically switch back to the safe version. Interestingly, some other Bose websites like worldwide.bose.com do have this protection — but the main website does not.

EVIDENCE	`curl -sI https://www.bose.com | grep -i strict`
	`(empty — no output returned)`
	
	`curl -sI https://www.bose.com/home | grep -i strict`
	`(empty — no output returned)`

BUSINESS IMPACT	Imagine shopping on bose.com using free WiFi at an airport or café. An attacker on the same network could silently intercept your connection and downgrade it from secure to insecure without you noticing. Once this happens, they can read everything you type — your login password, payment card details, and personal information — in plain text. This is one of the most common attacks carried out on public networks and is easily preventable.
REMEDIATION	Add a single line of configuration to the web server that tells browsers: "Always use the secure version of this website, for at least one year." This takes only a few minutes to configure and immediately protects all visitors. Bose should also register the website on a public browser safety list (hstspreload.org) to enforce this rule automatically in all major browsers.

SCREENSHOT EVIDENCE

📷 📷 CURL GREP STRICT — NO HSTS HEADER RETURNED (EMPTY OUTPUT)

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com | grep -i strict

┌──(kali㉿kali)-[~]
└─$ whatweb https://www.bose.com
https://www.bose.com [301 Moved Permanently] Cookies[_cfuvid,dwsid], Country[
UNITED STATES][US], DemandWare eCommerce System, HTTPServer[cloudflare], Http
Only[_cfuvid,dwsid], IP[104.18.36.26], RedirectLocation[https://www.bose.com/
home], UncommonHeaders[cf-ray,x-dwsid-samesite,cf-cache-status,alt-svc]
https://www.bose.com/home [200 OK] Cookies[__cq_dnt,cqcid,cquid,dw_dnt,dwac_a
2c7a7f1273c261f0de9e9e739,dwanonymous_75f93802d85d401ae747bf3a13f1fc14,sid],
Country[UNITED STATES][US], DemandWare eCommerce System, Email[example@domain
.com], Frame, Google-Tag-Manager, HTML5, HTTPServer[cloudflare], IP[104.18.36
.26], Script[application/ld+json,text/javascript], Title[Headphones, Earbuds,
 Speakers, Soundbars, &amp; More%0A        | Bose][Title element contains new
line(s)!], UncommonHeaders[cf-ray,x-content-type-options,content-security-pol
icy,x-dw-request-base-id,cf-cache-status,alt-svc], X-UA-Compatible[ie=edge]
```

BOSE-003

Wildcard CORS Policy on worldwide.bose.com

HIGH

ASSET	worldwide.bose.com
DESCRIPTION	The worldwide.bose.com website is configured to accept requests from any website on the internet. This is controlled by a setting called CORS (Cross-Origin Resource Sharing). Currently, a wildcard symbol (*) is used — meaning "allow everyone." A properly secured website should only accept requests from specific, trusted websites it knows about — not from every website on the internet.
EVIDENCE	`access-control-allow-origin: *` `access-control-allow-methods: GET, POST, PUT, DELETE, OPTIONS`
BUSINESS IMPACT	Imagine your online banking app accepted requests from any website, not just your bank's own pages. A malicious or hacked website could then silently make requests to your bank on your behalf while you are browsing. In the same way, a fake or compromised website could make requests to Bose's servers on behalf of a logged-in Bose customer — potentially reading their account details or making changes without their knowledge. This risk is even greater combined with the server information exposed in BOSE-001.
REMEDIATION	Change the server setting from "accept requests from everyone" to "only accept requests from bose.com." This is a one-line configuration change on the server and takes only minutes to implement. Also limit the allowed request types to only those the website actually needs.

SCREENSHOT EVIDENCE

📷 📷 WORLDWIDE.BOSE.COM — ACCESS-CONTROL-ALLOW-ORIGIN: * (WILDCARD CORS)

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com/home | grep -iE "x-frame|permissions-policy
|referrer-policy|x-xss"

┌──(kali㉿kali)-[~]
└─$ curl -sI https://worldwide.bose.com/support
HTTP/2 301
content-length: 0
location: https://www.bose.ae/en_ae/support.html
access-control-allow-methods: GET, POST, PUT, DELETE, OPTIONS
access-control-allow-origin: *
cache-control: no-cache, no-store, max-age=0, must-revalidate
date: Wed, 25 Feb 2026 07:26:30 GMT
expires: 0
nebula-response-details: reason: Exact match; rule-id: cdf82dbf-2746-403d-a68
2-1bcdfafd6df1
pragma: no-cache
server: ambassador-external
strict-transport-security: max-age=31536000 ; includeSubDomains
x-content-type-options: nosniff
x-envoy-decorator-operation: pulsar.pulsar-v1.svc.cluster.local:80/*
x-envoy-peer-metadata: ChoK[illegible]FOUF9DT05UQUlORVJTEggaBnB1bHNhcgoa[illegible]TFVTVEVSX0
lEEgwaCkt1YmVybmV0ZXMKHwo[illegible]VNUSU9
fVkVSU0lPThIIGgYxLjE5LjAK[illegible]KHGFw
cC5rdWJl[illegible]CmRlc
GF[illegible]b3ktMi
4[illegible]cml0eS5
p[illegible]5pY2FsLW5h
b[illegible]EggaBjEuM
T[illegible]hfSUQSDx
oN[illegible]ngKCU5BTUV
TUE[illegible]aXMvYXBwcy92MS9u
YW1l[illegible]KgwEKEVBMQVRGT1JNX01FVEFEQ
VRBEm4q[illegible]aWxhYmlsaXR5X3pvbmUSDBoKZXUtd2VzdC0xYgooCg9hd3NfaW5zdG
FuY2VfaWQSFRoTaS0wODM2MjY0MmY2NmYwYmRkZgoZCgphd3NfcmVnaW9uEgsaCWV1LXdlc3QtMQo
ZCg1XT1JLTE9BRF9OQU1FEggaBnB1bHNhcg==
x-envoy-peer-metadata-id: sidecar~10.106.72.149~pulsar-66d98648dc-jj82l.pulsa
r-v1~pulsar-v1.svc.cluster.local
x-envoy-upstream-service-time: 8
x-frame-options: DENY
x-xss-protection: 1; mode=block
x-cache: Miss from cloudfront
via: 1.1 a4722330b218f0fafaa9aed657871702.cloudfront.net (CloudFront)
x-amz-cf-pop: DXB53-P1
alt-svc: h3=":443"; ma=86400
x-amz-cf-id: Hm-a-f7ZL9BQWBQRIjsZar-3hP2lMwUfLe8XQEYs1LYlUKTw1ybAlQ==
```

BOSE-004

Multiple Session Cookies Missing HttpOnly Flag

HIGH

ASSET	www.bose.com
DESCRIPTION	When you browse www.bose.com, the website stores small pieces of data in your browser called cookies. These cookies remember who you are and keep you logged in. However, 7 of these cookies are missing a basic security setting called HttpOnly — which means they can be read by scripts (small programs) running on the page. Security-sensitive cookies should never be readable by scripts. The affected cookies are the ones that manage your login session and shopping identity on the site.

EVIDENCE	`set-cookie: dwac_a2c7a7f1273c261f0de9e9e739=...; Secure; SameSite=None (NO HttpOnly)`
	`set-cookie: cqcid=...; Secure; SameSite=None (NO HttpOnly)`
	`set-cookie: sid=...; Secure; SameSite=None (NO HttpOnly)`
	`+ 4 more cookies without HttpOnly flag`

BUSINESS IMPACT	If any malicious code ever runs on the bose.com website — for example through a hacked advertising tool or a compromised third-party plugin — it could instantly steal all 7 of these cookies. With your session cookies stolen, an attacker can log into your Bose account as if they were you, without ever needing your password. They could view your order history, access saved payment methods, or make purchases on your behalf.
REMEDIATION	Add one word — "HttpOnly" — to the cookie settings in Bose's website platform configuration. This single change tells the browser: "this cookie cannot be read by scripts — it can only be used for keeping the user logged in." This is a standard security setting available in all major e-commerce platforms and should take a developer less than an hour to implement and test.

SCREENSHOT EVIDENCE

📷 📷 CURL /HOME — MULTIPLE SESSION COOKIES MISSING HTTPONLY FLAG

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com/home
HTTP/2 200
date: Wed, 25 Feb 2026 07:13:11 GMT
content-type: text/html;charset=UTF-8
cf-ray: 9d35660e0c615633-DXB
set-cookie: dwac_a2c7a7f1273c261f0de9e9e739=f-[redacted]d
3I%3D|dw-only|||USD|false|US%2FEastern|true; Path=/; Secure; SameSite=None
set-cookie: cqcid=[redacted]2s; Path=/; Secure; SameSite=None
set-cookie: cquid=[redacted]|; Path=/; Secure; SameSite=None
set-cookie: sid=f-E2[redacted]3I; Path=/; Secure; SameSite
=None
set-cookie: dwanonymous_75f93802d85d401ae747bf3a13f1fc14=be[redacted]
aRmW2s; Version=1; Comment="Demandware anonymous cookie for site Sites-Bose_U
S-Site"; Max-Age=15552000; Expires=Mon, 24 Aug 2026 07:13:11 GMT; Path=/; Sec
ure; SameSite=None
set-cookie: __cq_dnt=0; Path=/; Secure; SameSite=None
set-cookie: dw_dnt=0; Path=/; Secure; SameSite=None
set-cookie: dwsid=[redacted]TUwC2D
_fo_Ty2-4GuQiz0a_9ZanfTiCTQ==; path=/; HttpOnly; Secure; SameSite=None
set-cookie: _cfuvid=pW[redacted]2003591694
-0.0.1.1-604800000; path=/; domain=.www.bose.com; HttpOnly; Secure; SameSite=
None
x-content-type-options: nosniff
x-dw-request-base-id: JtrX69QOnmkBAAB_
dnt: 1
content-security-policy: frame-ancestors 'self'
cache-control: no-cache, no-store, must-revalidate
pragma: no-cache
expires: Thu, 01 Dec 1994 16:00:00 GMT
vary: accept-encoding
cf-cache-status: DYNAMIC
server: cloudflare
alt-svc: h3=":443"; ma=86400


┌──(kali㉿kali)-[~]
└─$ # Check support subdomain (it's in scope!)
curl -sI https://support.bose.com
HTTP/2 301
content-length: 1
location: https://worldwide.bose.com/support
x-content-type-options: nosniff
cache-control: no-cache,must-revalidate,max-age=0,no-store,private
expires: Thu, 01 Jan 1970 00:00:00 GMT
date: Wed, 25 Feb 2026 07:13:58 GMT
akamai-grn: 0.cca4c117.1772003638.a95cc858
set-cookie: CookieConsentPolicy=0:1; path=/; expires=Thu, 25-Feb-2027 07:13:5
8 GMT; Max-Age=31536000; secure
set-cookie: LSKey-c$CookieConsentPolicy=0:1; path=/; expires=Thu, 25-Feb-2027
 07:13:58 GMT; Max-Age=31536000; secure
x-origin-cache-control: no-cache,must-revalidate,max-age=0,no-store,private
x-cache: Miss from cloudfront
via: 1.1 482f094812f3b85fad91a822889b44f8.cloudfront.net (CloudFront)
x-amz-cf-pop: DXB52-P2
x-amz-cf-id: h9Hg5OSPBqghj_GGUywGzWvloQYuA4NBULjYBTYBHZAP5gMylItWSA==
vary: Origin
```

BOSE-005

Full Technology Stack Disclosure via Response Headers

MEDIUM

ASSET	www.bose.com, www.bose.ae
DESCRIPTION	When you visit bose.com or bose.ae, the website accidentally tells visitors — and potential attackers — exactly which software it is built on. Hidden technical messages reveal the e-commerce platform (Salesforce Commerce Cloud), caching software and its version (Varnish v4), multiple content delivery networks in use (Cloudflare, CloudFront, Akamai), and even the internal server name ("Bose corp."). A well-secured website would hide all of this from public view.

EVIDENCE	`whatweb: DemandWare eCommerce System detected`
	`server: Bose corp. (bose.ae — internal server name)`
	`server: ambassador-external (worldwide.bose.com)`
	`x-page-speed: 1.13.35.2-0`
	`via: 1.1 varnish-v4 (cache version exposed)`
	`x-varnish: 55674875 37459265`

BUSINESS IMPACT	This is similar to a shop displaying a sign on its door that says: "We use Brand X alarm system, model Y, installed in 2019." A burglar can then look up that exact alarm system to find known weaknesses. In the same way, an attacker who knows exactly which software versions Bose uses can look up known security vulnerabilities for those versions and target them specifically. It saves attackers significant research time.
REMEDIATION	Configure the web servers to remove or hide all software version information from their public responses. This is a standard server configuration change. The website will continue to work exactly the same for all visitors — they will simply no longer receive this extra technical information.

SCREENSHOT EVIDENCE

📷 📷 WHATWEB — DEMANDWARE, CLOUDFLARE, TECH STACK FINGERPRINTED

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com | grep -i strict

┌──(kali㉿kali)-[~]
└─$ whatweb https://www.bose.com
https://www.bose.com [301 Moved Permanently] Cookies[_cfuvid,dwsid], Country[
UNITED STATES][US], DemandWare eCommerce System, HTTPServer[cloudflare], Http
Only[_cfuvid,dwsid], IP[104.18.36.26], RedirectLocation[https://www.bose.com/
home], UncommonHeaders[cf-ray,x-dwsid-samesite,cf-cache-status,alt-svc]
https://www.bose.com/home [200 OK] Cookies[__cq_dnt,cqcid,cquid,dw_dnt,dwac_a
2c7a7f1273c261f0de9e9e739,dwanonymous_75f93802d85d401ae747bf3a13f1fc14,sid],
Country[UNITED STATES][US], DemandWare eCommerce System, Email[example@domain
.com], Frame, Google-Tag-Manager, HTML5, HTTPServer[cloudflare], IP[104.18.36
.26], Script[application/ld+json,text/javascript], Title[Headphones, Earbuds,
 Speakers, Soundbars, &amp; More%0A        | Bose][Title element contains new
line(s)!], UncommonHeaders[cf-ray,x-content-type-options,content-security-pol
icy,x-dw-request-base-id,cf-cache-status,alt-svc], X-UA-Compatible[ie=edge]
```

📷 📷 BOSE.AE — SERVER: BOSE CORP., X-VARNISH, X-PAGE-SPEED DISCLOSED

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.ae/en_ae/support.html | head -30
HTTP/2 200
content-type: text/html;charset=utf-8
date: Tue, 24 Feb 2026 10:26:39 GMT
x-content-type-options: nosniff
x-xss-protection: 1; mode=block
server: Bose corp.
x-frame-options: SAMEORIGIN
xkey: host:www.bose.ae
xkey: global:all
xkey: path:/en_ae/support.html
xkey: publish:gdp-prod-blue-publish-0
x-page-speed: 1.13.35.2-0
x-varnish-cache-ttl: 31536000
cache-control: max-age=86400
x-varnish: 55674875 37459265
via: 1.1 varnish-v4, 1.1 37b2f92df6e1a03e444936f4e7d32076.cloudfront.net (Clo
udFront)
x-varnish-cache: HIT
x-varnish-cache-age: 44822
set-cookie: AWSALBAPP-0=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
set-cookie: AWSALBAPP-1=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
set-cookie: AWSALBAPP-2=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
set-cookie: AWSALBAPP-3=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
strict-transport-security: max-age=604800
vary: Accept-Encoding
x-cache: Hit from cloudfront
x-amz-cf-pop: DXB52-P1
x-amz-cf-id: t68Bi5tEUazkHjzWE2pXhNpkYKW-pCQWZXV6rxD-kdYVDm-xh2oTtA==
age: 76208
```

BOSE-006

MEDIUM

Incomplete Content Security Policy

ASSET	www.bose.com
DESCRIPTION	Every website can include a security rulebook called a Content Security Policy (CSP) that tells browsers exactly which sources of content are trusted and allowed to load on the page. Bose's website only has one rule in this rulebook — it says "do not allow this page to be embedded inside other websites." That is a useful rule, but it is only one out of many important protections. All other rules — about which scripts, images, and external tools are allowed to run — are completely missing.
EVIDENCE	`content-security-policy: frame-ancestors 'self'` `(Missing: script-src, style-src, img-src, connect-src, default-src directives)`
BUSINESS IMPACT	Without a proper content rulebook, if any third-party tool on the Bose website gets hacked — for example an analytics tracker or advertising script — that tool could run harmful code directly in your browser. This could silently steal your login details, redirect you to a fake website, or record everything you type on the page — all while the website looks completely normal to you.
REMEDIATION	Create a comprehensive content rulebook that lists exactly which trusted sources are allowed to load content on bose.com. This requires the development team to identify all legitimate external tools currently used on the site, then write and test the policy. Modern security tools can help generate this automatically by monitoring the site before enforcement is switched on.

SCREENSHOT EVIDENCE

📷 📷 CURL /HOME — CSP ONLY HAS FRAME-ANCESTORS, ALL OTHER DIRECTIVES MISSING

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com/home
HTTP/2 200
date: Wed, 25 Feb 2026 07:13:11 GMT
content-type: text/html;charset=UTF-8
cf-ray: 9d35660e0c615633-DXB
set-cookie: dwac_a2c7a7f1273c261f0de9e9e739=f-[redacted]d
3I%3D|dw-only|||USD|false|US%2FEastern|true; Path=/; Secure; SameSite=None
set-cookie: cqcid=[redacted]2s; Path=/; Secure; SameSite=None
set-cookie: cquid=[redacted]|; Path=/; Secure; SameSite=None
set-cookie: sid=f-E2[redacted]3I; Path=/; Secure; SameSite
=None
set-cookie: dwanonymous_75f93802d85d401ae747bf3a13f1fc14=be[redacted]
aRmW2s; Version=1; Comment="Demandware anonymous cookie for site Sites-Bose_U
S-Site"; Max-Age=15552000; Expires=Mon, 24 Aug 2026 07:13:11 GMT; Path=/; Sec
ure; SameSite=None
set-cookie: __cq_dnt=0; Path=/; Secure; SameSite=None
set-cookie: dw_dnt=0; Path=/; Secure; SameSite=None
set-cookie: dwsid=[redacted]TUwC2D
_fo_Ty2-4GuQiz0a_9ZanfTiCTQ==; path=/; HttpOnly; Secure; SameSite=None
set-cookie: _cfuvid=pW[redacted]2003591694
-0.0.1.1-604800000; path=/; domain=.www.bose.com; HttpOnly; Secure; SameSite=
None
x-content-type-options: nosniff
x-dw-request-base-id: JtrX69QOnmkBAAB_
dnt: 1
content-security-policy: frame-ancestors 'self'
cache-control: no-cache, no-store, must-revalidate
pragma: no-cache
expires: Thu, 01 Dec 1994 16:00:00 GMT
vary: accept-encoding
cf-cache-status: DYNAMIC
server: cloudflare
alt-svc: h3=":443"; ma=86400


┌──(kali㉿kali)-[~]
└─$ # Check support subdomain (it's in scope!)
curl -sI https://support.bose.com
HTTP/2 301
content-length: 1
location: https://worldwide.bose.com/support
x-content-type-options: nosniff
cache-control: no-cache,must-revalidate,max-age=0,no-store,private
expires: Thu, 01 Jan 1970 00:00:00 GMT
date: Wed, 25 Feb 2026 07:13:58 GMT
akamai-grn: 0.cca4c117.1772003638.a95cc858
set-cookie: CookieConsentPolicy=0:1; path=/; expires=Thu, 25-Feb-2027 07:13:5
8 GMT; Max-Age=31536000; secure
set-cookie: LSKey-c$CookieConsentPolicy=0:1; path=/; expires=Thu, 25-Feb-2027
 07:13:58 GMT; Max-Age=31536000; secure
x-origin-cache-control: no-cache,must-revalidate,max-age=0,no-store,private
x-cache: Miss from cloudfront
via: 1.1 482f094812f3b85fad91a822889b44f8.cloudfront.net (CloudFront)
x-amz-cf-pop: DXB52-P2
x-amz-cf-id: h9Hg5OSPBqghj_GGUywGzWvloQYuA4NBULjYBTYBHZAP5gMylItWSA==
vary: Origin
```

BOSE-007

HSTS max-age Too Short on bose.ae

MEDIUM

ASSET	www.bose.ae
DESCRIPTION	The bose.ae website does have a security setting that tells browsers to always use a secure connection (unlike the main bose.com — see BOSE-002). However, this setting is only configured to last for 7 days. After 7 days, the browser's memory of "always use the secure version here" expires and the protection is gone. The industry-wide standard is to set this memory to last for a minimum of 1 full year.
EVIDENCE	`strict-transport-security: max-age=604800` `(Current: 7 days — Recommended minimum: 365 days / 31,536,000 seconds)`
BUSINESS IMPACT	If a customer visits bose.ae and then does not return for more than a week, their browser's "always use secure connection" memory expires. The next time they visit — especially on an unsecured public network — they could be exposed to the same interception risk described in BOSE-002. The protection is there, but it is too short-lived to be reliably effective.
REMEDIATION	Change one number in the server configuration — increase the expiry from 604,800 seconds (7 days) to 31,536,000 seconds (1 year). This is a one-line change that takes only minutes and immediately brings the site in line with the industry standard. Adding the site to the HSTS preload list is also recommended as a further step.

SCREENSHOT EVIDENCE

📷 📷 BOSE.AE — STRICT-TRANSPORT-SECURITY MAX-AGE=604800 (ONLY 7 DAYS)

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.ae/en_ae/support.html | head -30
HTTP/2 200
content-type: text/html;charset=utf-8
date: Tue, 24 Feb 2026 10:26:39 GMT
x-content-type-options: nosniff
x-xss-protection: 1; mode=block
server: Bose corp.
x-frame-options: SAMEORIGIN
xkey: host:www.bose.ae
xkey: global:all
xkey: path:/en_ae/support.html
xkey: publish:gdp-prod-blue-publish-0
x-page-speed: 1.13.35.2-0
x-varnish-cache-ttl: 31536000
cache-control: max-age=86400
x-varnish: 55674875 37459265
via: 1.1 varnish-v4, 1.1 37b2f92df6e1a03e444936f4e7d32076.cloudfront.net (Clo
udFront)
x-varnish-cache: HIT
x-varnish-cache-age: 44822
set-cookie: AWSALBAPP-0=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
set-cookie: AWSALBAPP-1=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
set-cookie: AWSALBAPP-2=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
set-cookie: AWSALBAPP-3=_remove_; Expires=Tue, 03 Mar 2026 10:26:39 GMT; Path
=/
strict-transport-security: max-age=604800
vary: Accept-Encoding
x-cache: Hit from cloudfront
x-amz-cf-pop: DXB52-P1
x-amz-cf-id: t68Bi5tEUazkHjzWE2pXhNpkYKW-pCQWZXV6rxD-kdYVDm-xh2oTtA==
age: 76208
```

BOSE-008

Missing Security Headers on Primary Domain

MEDIUM

ASSET	www.bose.com
DESCRIPTION	Several standard protective instructions that websites send to browsers are completely absent from www.bose.com. These instructions — called security headers — act like a checklist of rules given to your browser: "do not allow this page inside other pages," "do not share our page address with other websites," "block suspicious scripts automatically." When we checked, four of these standard protective instructions were missing from the main Bose website.
EVIDENCE	`curl -sI https://www.bose.com/home | grep -iE 'x-frame|permissions-policy|referrer-policy|x-xss'` `(empty — no output returned for any of these headers)`
BUSINESS IMPACT	Without these browser instructions, visitors to bose.com are left without several standard default protections. For example, without one of these instructions (X-Frame-Options), attackers can embed the Bose website invisibly inside a fake page and trick users into clicking things they did not mean to click — known as clickjacking. Without another instruction (Referrer-Policy), users' browsing activity on Bose pages gets quietly shared with third-party advertising and analytics companies.
REMEDIATION	Add four standard security instructions to the web server configuration. These are widely used, well-documented settings that take less than an hour to add. They do not change how the website looks or works for visitors — they simply give browsers clearer, safer instructions about how to handle the page.

SCREENSHOT EVIDENCE

📷 📷 CURL GREP — X-FRAME-OPTIONS, PERMISSIONS-POLICY, REFERRER-POLICY ALL MISSING

```
┌──(kali㉿kali)-[~]
└─$ curl -sI https://www.bose.com/home | grep -iE "x-frame|permissions-policy
|referrer-policy|x-xss"

┌──(kali㉿kali)-[~]
└─$ curl -sI https://worldwide.bose.com/support
HTTP/2 301
content-length: 0
location: https://www.bose.ae/en_ae/support.html
access-control-allow-methods: GET, POST, PUT, DELETE, OPTIONS
access-control-allow-origin: *
cache-control: no-cache, no-store, max-age=0, must-revalidate
date: Wed, 25 Feb 2026 07:26:30 GMT
expires: 0
nebula-response-details: reason: Exact match; rule-id: cdf82dbf-2746-403d-a68
2-1bcdfafd6df1
pragma: no-cache
server: ambassador-external
strict-transport-security: max-age=31536000 ; includeSubDomains
x-content-type-options: nosniff
x-envoy-decorator-operation: pulsar.pulsar-v1.svc.cluster.local:80/*
x-envoy-peer-metadata: ChoK[redacted]
lEEgwaCkt1YmVybmV0ZXMKHwo[redacted]VNUSU9
fVkVSU0lPThIIGgYxLjE5LjAK[redacted]KHGFw
cC5rdWJl[redacted]CmRlc
GF[redacted]b3ktMi
4[redacted]cml0eS5
p[redacted]5pY2FsLW5h
b[redacted]EggaBjEuM
T[redacted]hfSUQSDx
oN[redacted]ngKCU5BTUV
TUE[redacted]aXMvYXBwcy92MS9u
YW1l[redacted]KgwEKEVBMQVRGT1JNX01FVEFEQ
VRBEm4q[redacted]ZnaWxhYmlsaXR5X3pvbmUSDBoKZXUtd2VzdC0xYgooCg9hd3NfaW5zdG
FuY2VfaWQSFRoTaS0wODM2MjY0MmY2NmYwYmRkZgoZCgphd3NfcmVnaW9uEgsaCWV1LXdlc3QtMQo
ZCg1XT1JLTE9BRF9OQU1FEggaBnB1bHNhcg==
x-envoy-peer-metadata-id: sidecar~10.106.72.149~pulsar-66d98648dc-jj82l.pulsa
r-v1~pulsar-v1.svc.cluster.local
x-envoy-upstream-service-time: 8
x-frame-options: DENY
x-xss-protection: 1; mode=block
x-cache: Miss from cloudfront
via: 1.1 a4722330b218f0fafaa9aed657871702.cloudfront.net (CloudFront)
x-amz-cf-pop: DXB53-P1
alt-svc: h3=":443"; ma=86400
x-amz-cf-id: Hm-a-f7ZL9BQWBQRIjsZar-3hP2lMwUfLe8XQEYs1LYlUKTw1ybAlQ==
```

BOSE-009

Hardcoded Legacy Expiry Dates in Cache Headers

LOW

ASSET	www.bose.com, support.bose.com
DESCRIPTION	Hidden inside Bose's server responses are two expiry dates that are clearly wrong — one from December 1994 and one from January 1970 (the very beginning of computer time). These are old placeholder dates that were set up long ago in the server configuration and were never corrected. While they do not directly cause a security problem on their own, they are a sign that certain server settings have not been reviewed or updated in many years.
EVIDENCE	`www.bose.com: expires: Thu, 01 Dec 1994 16:00:00 GMT` `support.bose.com: expires: Thu, 01 Jan 1970 00:00:00 GMT`
BUSINESS IMPACT	This is similar to finding that a building's maintenance logbook has not been signed since 1994. It does not mean the building is about to collapse — but it does suggest that nobody has been reviewing these particular settings, which raises the question of whether other nearby configurations have also been overlooked over the years.
REMEDIATION	Update the server configuration to use modern, correct expiry settings. This is a straightforward maintenance task — remove the old hardcoded dates and replace them with settings that update automatically based on current time. Where a "no caching" instruction is already present, the outdated expiry date can simply be removed as it is no longer needed.

SCREENSHOT EVIDENCE

📷 📷 CURL WWW.BOSE.COM — EXPIRES: THU, 01 DEC 1994 16:00:00 GMT

Home | My Computer | kali-linux-2025.2-vmware-a...

1 2 3 4

Session Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ curl -I https://www.bose.com
HTTP/2 301
date: Wed, 25 Feb 2026 06:58:10 GMT
content-length: 0
location: https://www.bose.com/home
cf-ray: 9d35500ace69941f-DXB
accept-ranges: bytes
x-dwsid-samesite: None
cache-control: no-cache, no-store, must-revalidate
pragma: no-cache
expires: Thu, 01 Dec 1994 16:00:00 GMT
set-cookie: dwsid=[illegible]
4aFM1gb05liS5egPmVK5O2faOEg==; path=/; HttpOnly; Secure; SameSite=None
set-cookie: _cfuvid=[illegible]
-0.0.1.1-604800000; path=/; domain=.www.bose.com; HttpOnly; Secure; SameSite=
None
cf-cache-status: DYNAMIC
server: cloudflare
alt-svc: h3=":443"; ma=86400


┌──(kali㉿kali)-[~]
└─$ curl -s -D - https://www.bose.com -o /dev/null
HTTP/2 301
date: Wed, 25 Feb 2026 07:02:11 GMT
content-length: 0
location: https://www.bose.com/home
cf-ray: 9d3555f17ca8f08b-DXB
accept-ranges: bytes
x-dwsid-samesite: None
cache-control: no-cache, no-store, must-revalidate
pragma: no-cache
expires: Thu, 01 Dec 1994 16:00:00 GMT
set-cookie: dwsid=[illegible]
dY13BNCZ0ahTbRcQKBpzgul4hxw==; path=/; HttpOnly; Secure; SameSite=None
set-cookie: _cfuvid=[illegible]
-0.0.1.1-604800000; path=/; domain=.www.bose.com; HttpOnly; Secure; SameSite=
None
cf-cache-status: DYNAMIC
server: cloudflare
alt-svc: h3=":443"; ma=86400
```

BOSE-010

Example Email Address Exposed in Page Source

LOW

ASSET	www.bose.com/home
DESCRIPTION	A standard web scanning tool found a placeholder email address — "example@domain.com" — hidden inside the code of the bose.com homepage. This type of address is typically used by developers as a dummy placeholder while building a website and should be removed before the site goes live. Its presence suggests that some leftover development code was not fully cleaned up before being published to the public website.
EVIDENCE	`whatweb output: Email[example@domain.com]` `Source: www.bose.com/home page HTML`
BUSINESS IMPACT	On its own, this is a minor issue — the placeholder email address does not lead anywhere harmful. However, it indicates that the website may contain other leftover development content that was not intended to be public. It also reflects on the thoroughness of the final checks carried out before the website is updated and published.
REMEDIATION	Ask the development team to search the website code for any remaining placeholder or test content and remove it before the next deployment. This is a quick clean-up task that should take less than an hour.

04 Findings Summary

COMPLETE OVERVIEW OF ALL ISSUES

ID	FINDING	SEVERITY	ASSET
BOSE-001	Internal K8s & Cloud Metadata Exposed	CRITICAL	worldwide.bose.com
BOSE-002	Missing HSTS on Primary Domain	HIGH	www.bose.com
BOSE-003	Wildcard CORS Policy	HIGH	worldwide.bose.com
BOSE-004	Session Cookies Missing HttpOnly	HIGH	www.bose.com

ID	FINDING	SEVERITY	ASSET
BOSE-005	Technology Stack Disclosure	MEDIUM	www.bose.com, bose.ae
BOSE-006	Incomplete Content Security Policy	MEDIUM	www.bose.com
BOSE-007	HSTS max-age Too Short	MEDIUM	www.bose.ae
BOSE-008	Missing Security Headers	MEDIUM	www.bose.com
BOSE-009	Legacy Hardcoded Expiry Dates	LOW	www.bose.com
BOSE-010	Example Email in Page Source	LOW	www.bose.com

05 Positive Security Controls

WHAT BOSE IS ALREADY DOING WELL

The following security measures were found to be working correctly. These are things Bose is already doing well:

✓ TLS CONFIGURATION

All encrypted connections use the highest security grade (Grade A). Bose uses modern, strong encryption — meaning all data sent between visitors and the website is very well protected from eavesdropping.

✓ DMARC POLICY

Bose's email security is set to the strictest level — meaning attackers cannot send fake emails pretending to be from @bose.com. All suspicious emails are automatically rejected before they reach anyone's inbox.

✓ SPF RECORD

Bose has correctly listed all the email services that are authorised to send emails on its behalf. This prevents unauthorised senders from impersonating Bose by email.

✓ DKIM

Bose uses a digital signature on its emails that allows recipients to verify the email genuinely came from Bose and was not tampered with during delivery.

✓ HTTPS ENFORCEMENT

All Bose websites automatically redirect visitors from insecure (HTTP) to secure (HTTPS) connections. Your connection is always encrypted when visiting any Bose website.

✓ X-CONTENT-TYPE-OPTIONS

Bose correctly instructs browsers not to try to guess or reinterpret the type of files they receive from the website — this prevents a category of attacks where files are misidentified and executed incorrectly.

Supporting Evidence — Positive Controls

📷 NMAP SSL-ENUM-CIPHERS — TLS GRADE A CONFIRMED

```
┌──(kali㉿kali)-[~]
└─$ nmap --script ssl-enum-ciphers -p 443 www.bose.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-25 02:02 -0500
Nmap scan report for www.bose.com (104.18.36.26)
Host is up (0.0025s latency).
Other addresses for www.bose.com (not scanned): 172.64.151.230

PORT    STATE SERVICE
443/tcp open  https
| ssl-enum-ciphers:
|  TLSv1.2:
|    ciphers:
|      TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|      TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|      TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|      TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|      TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|      TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|      TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
|      TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|      TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|      TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (ecdh_x25519) - A
|      TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|      TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (ecdh_x25519) - A
|      TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|    compressors:
|      NULL
|    cipher preference: server
|_  least strength: A

Nmap done: 1 IP address (1 host up) scanned in 2.14 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -sV --open -p 80,443,8080,8443 www.bose.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-25 02:03 -0500
Nmap scan report for www.bose.com (172.64.151.230)
Host is up (0.0052s latency).
Other addresses for www.bose.com (not scanned): 104.18.36.26

PORT     STATE SERVICE  VERSION
80/tcp   open  http     Cloudflare http proxy
443/tcp  open  ssl/http Cloudflare http proxy
8080/tcp open  http     Cloudflare http proxy
8443/tcp open  ssl/http Cloudflare http proxy

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.13 seconds
```

📷 DIG — SPF + DMARC P=REJECT RECORDS VERIFIED

```
┌──(kali㉿kali)-[~]
└─$ dig TXT bose.com | grep -E "spf|dmarc|dkim"
dig TXT _dmarc.bose.com
bose.com.               5       IN      TXT     "v=spf1 include:%{ir}.%{v}.%{
d}.spf.has.pphosted.com include:9194398.spf03.hubspotemail.net include:sendgr
id.net ~all"

; <<>> DiG 9.20.18-1-Debian <<>> TXT _dmarc.bose.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 22654
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1220
; COOKIE: 3cfe9920a9a4f765cde5cc53699ea028c483aa4a1a08e460 (good)
;; QUESTION SECTION:
;_dmarc.bose.com.                IN      TXT

;; ANSWER SECTION:
_dmarc.bose.com.        5       IN      TXT     "v=DMARC1;p=reject;rua=mailto
:dmarc_rua@emaildefense.proofpoint.com; ruf=mailto:dmarc_ruf@emaildefense.pro
ofpoint.com;pct=100;fo=1"

;; Query time: 20 msec
;; SERVER: 192.168.202.2#53(192.168.202.2) (UDP)
;; WHEN: Wed Feb 25 02:09:28 EST 2026
;; MSG SIZE  rcvd: 214
```

📷 DIG DKIM — DEFAULT._DOMAINKEY.BOSE.COM TXT RECORD PRESENT

Home | My Computer | kali-linux-2025.2-vmware-a...

1 2 3 4

kali@kali: ~

Session Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ dig TXT default._domainkey.bose.com
dig TXT google._domainkey.bose.com

; <<>> DiG 9.20.18-1-Debian <<>> TXT default._domainkey.bose.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 40931
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1220
; COOKIE: adbf91a1940ca76cf3291c5f699ea445b2afbdcd17f62e78 (good)
;; QUESTION SECTION:
;default._domainkey.bose.com.   IN      TXT

;; ANSWER SECTION:
default._domainkey.bose.com. 5  IN      TXT     "p=MIGfMA0GCSqGSIb3DQEBAQUAA4
GNADCBiQKBgQDQczT4UpoA2wltZyT0Wjhh/C0yAsFqZT3FunHc2FCGtcAbrECKHlpfQDhIFctNIaE
5qcdhLYwiwlHM4xd6I10hm/Ou/f4S2voyXqSolhBE/5YXwWbDr8/cC1TObNX3H1Fw57O9r7Dj2LSj
+63he+0g+JEM3dlXUpDhX40A0+umDwIDAQAB"

;; Query time: 24 msec
;; SERVER: 192.168.202.2#53(192.168.202.2) (UDP)
;; WHEN: Wed Feb 25 02:27:01 EST 2026
;; MSG SIZE  rcvd: 315


; <<>> DiG 9.20.18-1-Debian <<>> TXT google._domainkey.bose.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 49465
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1220
; COOKIE: 5dd8a408c57d1d67c374265d699ea4451c6a5b6e87d85a50 (good)
;; QUESTION SECTION:
;google._domainkey.bose.com.    IN      TXT

;; AUTHORITY SECTION:
bose.com.               5       IN      SOA     ns-1849.awsdns-39.co.uk. awsd
ns-hostmaster.amazon.com. 1 7200 900 1209600 86400

;; Query time: 24 msec
;; SERVER: 192.168.202.2#53(192.168.202.2) (UDP)
;; WHEN: Wed Feb 25 02:27:01 EST 2026
;; MSG SIZE  rcvd: 167
```

06 Conclusion & Recommendations

SUMMARY & PRIORITY ACTIONS

This security check of Bose's public websites found a total of **10 issues across four severity levels**. While Bose has several strong security measures already in place — including excellent email protection and strong encrypted connections — the accidental leaking of internal server details on worldwide.bose.com is the most urgent issue and should be fixed immediately.

All issues identified are fixable without major development work. Most can be resolved through simple server configuration changes. None required any exploitation, attack, or access beyond what a regular website visitor would see.

6.1 — Priority Remediation Order

PRIORITY	FINDING ID	ACTION REQUIRED	TIMELINE
P1	BOSE-001	Strip Envoy metadata headers at ingress gateway	Immediate (24–48hrs)
P2	BOSE-004	Add HttpOnly flag to all session cookies	Within 1 week
P3	BOSE-002	Implement HSTS on www.bose.com	Within 1 week
P4	BOSE-003	Replace wildcard CORS with explicit allowlist	Within 2 weeks
P5	BOSE-006	Implement full Content Security Policy	Within 1 month
P6	BOSE-005/007/008	Remove version headers, fix HSTS max-age, add missing headers	Within 1 month

This report was prepared as part of the **Future Interns Cyber Security Internship Programme** (Track: CS, Task 1). All testing was carried out ethically, passively, and within the authorised scope of the Bose security research programme

on HackerOne. No vulnerabilities were exploited, no data was accessed, and no systems were changed during this assessment.